RESUMEN DEL ESQUEMA DE AUDITORÍA

Elemento	Descripción
Objeto de auditoría	Red LAN del instituto (capa física, capa lógica, gestión administrativa)
Alcance temporal	3 días de trabajo de campo + 5 días de post-auditoría
Metodología principal	Enfoque mixto (cuantitativo + cualitativo), basado en riesgos (ISO 27005)
Estándares integrados	ISO 19011 (gestión de auditorías), ISO 27001/27002 (seguridad), TIA/EIA (cableado), COBIT 2019 (gobernanza)
Instrumentos	Checklists, cuestionarios, pruebas técnicas (ping, traceroute, cable tester), entrevistas, observación directa
Entregable final	Informe de auditoría con hallazgos, matriz de riesgos y plan de mejora

Dominio 1: Capa Física

Ítem a Auditar	Instrumento / Técnica	Metodología	Criterio / Norma
Ubicación y seguridad del Router y Switch	Inspección ocular, fotografías, medición de accesibilidad	Observación directa	ISO 27001 A.11.1 (Áreas seguras), COBIT APO13.05 (Gestión de seguridad física)
Gabinete / Rack (existencia, cerradura, anclaje)	Checklist Módulo I, cinta métrica, prueba de estabilidad	Verificación de cumplimiento	ANSI/TIA-569 (Espacios de telecomunicaciones)
UPS y sistema de respaldo eléctrico	Verificación de indicadores LED, prueba de conmutación a batería	Prueba de funcionalidad	ISO 27001 A.11.2.2 (Protección contra fallos de energía)
Cableado horizontal (23 tendidos Cat6)	Inspección visual, cable tester, verificación de continuidad	Muestreo censal (100%)	ANSI/TIA-568-C (Cableado estructurado)
Canalización y protección de cables	Inspección visual, verificación de radios de curvatura, detección de puntos de tensión	Observación directa	ANSI/TIA-569 (Canalizaciones)
Conectores RJ45 (terminación y ponchado)	Inspección con lupa, verificación de secuencia de colores T568B	Verificación de cumplimiento	ANSI/TIA-568-C (Terminaciones)
Etiquetado de cables (banderín)	Inspección visual, verificación de nomenclatura contra mapa de red	Verificación de cumplimiento	ANSI/TIA-606-B (Administración y etiquetado)

Ítem a Auditar	Instrumento / Técnica	Metodología	Criterio / Norma
Rosetas / Faceplates (áreas de trabajo)	Inspección visual, verificación de fijación a pared/mueble	Observación directa	ANSI/TIA-568-C (Área de trabajo)
Patch cords de usuario (PC a roseta)	Inspección visual, verificación de longitud y condición física	Verificación de cumplimiento	ANSI/TIA-568-C (Cables de parcheo)

Dominio 2: Capa Lógica

Ítem a Auditar	Instrumento / Técnica	Metodología	Criterio / Norma
Segmentación de red (VLANs)	Acceso a consola del switch (si es administrable), comandos show vlan	Prueba técnica	ISO 27001 A.13.1.1 (Controles de red), COBIT DSS05.02 (Seguridad de red)
Configuración DHCP (rangos, IPs fijas por MAC)	Conexión de laptop auditora, comando ipconfig /all, verificación de IP asignada	Prueba de funcionalidad	ISO 27001 A.9.4.2 (Gestión de acceso seguro)
Servidores DNS configurados	Comando nslookup desde PC del laboratorio, verificación de respuesta	Prueba de funcionalidad	ISO 27001 A.13.1.3 (Separación de redes)
Filtrado de contenido web (Cloudflare Families)	Intentar acceder a sitios de prueba (ej. categoría adultos, malware) desde laboratorio	Prueba de penetración controlada	ISO 27001 A.13.1.3, Ley 787 (Protección de niños y adolescentes)

Ítem a Auditar	Instrumento / Técnica	Metodología	Criterio / Norma
Calidad de Servicio (QoS) / Control de ancho de banda	Simulación de tráfico (iPerf o descarga masiva), monitoreo de latencia en PC de dirección	Prueba de estrés	ISO 27001 A.17.2.1 (Disponibilidad de servicios)
Firewall de Windows en PCs administrativas	Comando wf.msc, verificación de regla de entrada bloqueando rango estudiantil	Verificación de cumplimiento	ISO 27001 A.13.1.1 (Controles de red)
Perfil de red (Pública vs Privada) en PCs dirección	Control Panel > Network and Sharing Center, verificación de perfil activo	Verificación de cumplimiento	ISO 27001 A.9.4.1 (Política de control de acceso)
Software de congelamiento en laboratorio	Reiniciar una PC del laboratorio, verificar persistencia de cambios (archivo de prueba)	Prueba de funcionalidad	COBIT DSS05.02 (Protección contra malware)
Antivirus y actualizaciones	Verificar presencia de antivirus, fecha de última actualización	Verificación de cumplimiento	ISO 27002 A.12.2.1 (Controles contra malware)

Dominio 3: Gestión Administrativa y Gobernanza de TI

Ítem a Auditar	Instrumento / Técnica	Metodología	Criterio / Norma
Políticas de uso de red y laboratorio	Entrevista semiestructurada (Cuestionario de 30 preguntas), solicitud de documentos	Revisión documental	COBIT APO01.06 (Definición de políticas), ISO 27002 A.7.1.1 (Políticas de seguridad)
Presupuesto asignado a TI	Entrevista con Director, solicitud de registros contables	Revisión documental	COBIT APO06.01 (Gestión de presupuesto)
Inventario de activos TI	Solicitar documento de inventario, verificar contra equipos físicos	Verificación de cumplimiento	ISO 27001 A.8.1.1 (Inventario de activos), COBIT DSS01.01 (Procesos de operación)
Roles y responsabilidades TI	Entrevista, verificación de nombramiento formal (si existe)	Revisión documental	COBIT APO01.04 (Definición de roles y responsabilidades)
Registro de incidentes de seguridad	Solicitar bitácora o libro de novedades	Revisión documental	ISO 27001 A.16.1.1 (Responsabilidades y procedimientos), COBIT DSS03.01 (Definición de incidentes)
Capacitación a docentes y personal	Entrevista, solicitud de constancias o registros de capacitación	Revisión documental	ISO 27002 A.7.2.2 (Concienciación, educación y capacitación), COBIT APO07.03 (Competencias del personal)

Ítem a Auditar	Instrumento / Técnica	Metodología	Criterio / Norma
Plan de continuidad y respaldo de configuración	Verificar existencia de respaldo del router (fotos o archivo de configuración)	Verificación de cumplimiento	ISO 27001 A.17.1.1 (Planificación de la continuidad), COBIT DSS04.03 (Planes de continuidad)

METODOLOGÍAS DE AUDITORÍA APLICADAS

Metodología	Descripción	Aplicación en esta auditoría
Enfoque basado en riesgos (ISO 27005)	Priorizar la auditoría en los activos y procesos de mayor riesgo para la institución	Se auditarán primero los riesgos críticos (R-001 a R-005) antes que los de menor impacto
Muestreo censal	Evaluar el 100% de la población cuando esta es pequeña y manejable	Se auditarán los 23 tendidos de cable (100%), las 23 PCs (100%)
Triangulación de evidencias	Cruzar al menos tres fuentes de evidencia para validar un hallazgo	Ejemplo: Para verificar filtrado DNS, se hará (1) prueba técnica, (2) entrevista al administrador, (3) captura de configuración del router
Ciclo PDCA (Plan-Do-Check-Act)	Estructura de mejora continua adaptada a la auditoría	Plan (planificación), Do (trabajo de campo), Check (análisis de hallazgos), Act (recomendaciones y seguimiento)
Gap Analysis (Análisis de brechas)	Comparar el estado actual contra un estado deseado (norma o estándar)	Se comparará cada hallazgo contra ISO 27001, TIA-568 o COBIT

Metodología	Descripción	Aplicación en esta auditoría
Walkthrough (Recorrido guiado)	El auditor recorre las instalaciones acompañado por el responsable del área	Se realizará un recorrido desde el router hasta el laboratorio y dirección

ESTÁNDARES, NORMAS Y FRAMEWORKS INTEGRADOS

4.1 Normas ISO (Gestión de Seguridad y Calidad)

Norma	Aplicación Específica
ISO 19011:2018	Directrices para la gestión de la auditoría (planificación, ejecución, informe, competencias del auditor)
ISO/IEC 27001:2022	Marco principal para seguridad de la información (Anexo A completo)
ISO/IEC 27002:2022	Buenas prácticas para implementar los controles de 27001
ISO/IEC 27005:2022	Gestión de riesgos de seguridad de la información (identificación, análisis, evaluación)
ISO/IEC 27007:2020	Guía específica para auditorías de sistemas de gestión de seguridad de la información (SG-SI)

4.2 Estándares TIA/EIA (Cableado Estructurado)

Estándar	Aplicación Específica
ANSI/TIA-568-C	Cableado de telecomunicaciones en edificios comerciales (categoría, terminaciones, longitudes, topología)
ANSI/TIA-569-C	Espacios y canalizaciones (ductos, bandejas, radios de curvatura)
ANSI/TIA-606-B	Administración y etiquetado de infraestructura (códigos de identificación)
ANSI/TIA-942	Infraestructura de centros de datos (aplicable parcialmente al área de comunicaciones)

4.3 Framework COBIT 2019 (Gobernanza y Gestión de TI)

Dominio COBIT	Proceso	Aplicación
APO (Align, Plan & Organize)	APO01 (Gestión del marco de TI), APO06 (Gestión de presupuesto), APO07 (Gestión de recursos humanos)	Evaluación de políticas, presupuesto y roles
DSS (Build, Run & Monitor)	DSS01 (Gestión de operaciones), DSS02 (Gestión de peticiones e incidentes), DSS03 (Gestión de problemas), DSS04 (Gestión de continuidad), DSS05 (Gestión de servicios de seguridad)	Evaluación de operaciones diarias, incidentes, continuidad y seguridad técnica
EDM (Evaluate, Direct & Monitor)	EDM03 (Gestión de riesgos), EDM04 (Gestión de recursos)	Supervisión de riesgos y recursos TI

4.4 Otras Referencias Normativas

Norma / Ley	Aplicación
Ley 787 (Código de la Niñez y Adolescencia de Nicaragua)	Obligación de proteger a menores de contenido inapropiado en internet
Ley 921 (Ley de Protección de Datos Personales de Nicaragua)	Confidencialidad de datos de estudiantes y personal
RFC 1918 (Direccionamiento privado)	Verificación de uso correcto de IPs privadas (192.168.x.x)